Cybersecurity and Privacy Challenges in Federated Learning for Medical Imaging

Deepak Kambala[1,3] Anurag Tummapudi[2]

[1]University College of Engineering Narasaraopet, JNTUK

[2]SRM University AP

[3]Prism Labs

deepakkambala@prism-labs.tech, anuragtummapudi@gmail.com

Abstract

Hospitals seek to combine data across institutions to build more accurate diagnostic models, but patient privacy regulations such as HIPAA, GDPR, and DPDP often prohibit direct data sharing. Federated learning (FL) addresses this by letting hospitals train models locally and share only model updates with a central aggregator, leaving raw patient data on-site. However, keeping data local does not automatically make the resulting system secure: a compromised participant can still corrupt the shared global model without ever touching another hospital's data. This paper surveys the major cybersecurity and privacy threats affecting federated learning in medical imaging (model and data poisoning, backdoor attacks, Byzantine participation, and gradient/inference leakage) and reviews the defenses proposed against them, including secure aggregation, differential privacy, Byzantine-robust aggregation rules, anomaly detection, and participant authentication. We then empirically evaluate these risks on a real pediatric chest X-ray dataset using a five-hospital federated simulation. In this five-hospital simulation, a single malicious hospital using label flipping combined with 8× update scaling reduces global classification accuracy from 79.8% to 50.0% under standard FedAvg aggregation. Three Byzantine-robust aggregation rules (Krum, Trimmed Mean, and coordinate-wise Median) recover accuracy to between 75.0% and 83.0%, despite offering comparable theoretical robustness guarantees, indicating that these methods are not interchangeable in practice, particularly under the non-IID data distributions typical of real hospital populations.

Keywords: federated learning, medical imaging, Byzantine-robust aggregation, differential privacy, poisoning attacks, healthcare AI security

1 Introduction

Machine learning models for medical image analysis (for example, classifying chest radiographs for pneumonia, or detecting tumors in CT and MRI scans) generally improve in accuracy and generalizability as the size and diversity of the training data increase. In practice, however, no single hospital holds enough labeled data, and enough diversity of patient populations, imaging equipment, and disease prevalence, to train a robust model on its own. Pooling data across institutions would help, but is frequently blocked by patient privacy regulation, institutional data-governance policy, and the practical difficulty of transferring large volumes of protected health information (PHI) between organizations.

Federated learning (FL) [1] was proposed as a way around this bottleneck. In FL, each participating institution trains a copy of a shared model on its own local data, and only the resulting model updates (gradients or weights) are transmitted to a central server, which aggregates them into a new global model that is redistributed for the next round. Raw patient data never leaves the hospital's infrastructure. Federated learning can reduce the need to transfer raw patient data between institutions, but the use of federated learning alone does not establish regulatory compliance with frameworks such as HIPAA in the United States, GDPR in the European Union, or the DPDP Act in India; each of these frameworks imposes additional requirements beyond data locality.

The central claim of this paper is that data locality is necessary but not sufficient for security. Because the aggregator must trust that client updates faithfully reflect honest local training, a participant that deviates from the protocol (whether through malice, misconfiguration, or a compromised institution) can still degrade or subvert the global model, and can in some cases extract information about other participants' data from the aggregation process itself. In a clinical setting, where a poisoned classifier can directly influence a diagnosis, these are not abstract concerns.

This paper makes three contributions. First, we synthesize the threat landscape specific to federated learning in medical imaging, organized around four attack classes: poisoning, backdoors, Byzantine participation, and inference/gradient leakage. Second, we summarize the corresponding defense space (secure aggregation, differential privacy, Byzantine-robust aggregation, anomaly detection, and participant authentication) and discuss the

trade-offs between them, since no single defense optimizes privacy, robustness, accuracy, and computational cost simultaneously. Third, we present an empirical study on a real chest X-ray dataset that quantifies the impact of a single malicious hospital on a five-hospital federation, and compares the recovery achieved by three widely cited Byzantine-robust aggregation rules under realistic, non-independent-and-identically-distributed (non-IID) hospital data.

2 Background: How Federated Learning Works

In the canonical FedAvg protocol [1], training proceeds in rounds. At the start of round t, the server broadcasts the current global model w_t to a subset of participating clients (hospitals). Each client k initializes a local copy of the model with w_t and performs several epochs of local stochastic gradient descent on its own private data, producing an updated local model w_t^k. Rather than sending its raw data, the client sends only the update w_t^k (or the difference $w_t^k - w_t$) back to the server. The server then computes a weighted average,

$$w_{t+1} = \sum_{k=1}^{K} \frac{n_k}{n} w_t^k, \tag{1}$$

where n_k is the number of local training examples at client k and $n = \sum_k n_k$ is the total across all participating clients. This process repeats for a fixed number of rounds or until convergence.

The key security property of this design is that the server never directly observes patient-level data. However, the server's aggregation step is, by construction, an unweighted or lightly weighted average of whatever each client chooses to submit. Nothing in the base protocol verifies that a client's submitted update in fact resulted from honest local training on real data, and nothing prevents a client from scaling, corrupting, or fabricating its update before submission. This is the attack surface explored in the remainder of this paper.

2.1 The Non-IID Problem in Healthcare

Federated learning was originally motivated by cross-device settings (e.g., keyboard prediction on mobile phones) where the underlying convergence theory typically assumes client data is drawn independently and identically from a shared distribution. Hospital data violates this assumption almost by definition: participating hospitals differ in disease prevalence, patient demographics, imaging hardware and acquisition protocols, and case mix. As a result, an honest hospital's update can look statistically unusual relative to the rest of the federation for entirely legitimate reasons. This matters directly for security, because many Byzantine-robust aggregation rules work by identifying and down-weighting updates that look anomalous relative to the group, a mechanism that risks conflating a hospital serving an atypical patient population with an actual attacker. Distinguishing natural data heterogeneity from adversarial behavior is, in our view, the central open problem for robust FL in clinical deployments, and we return to it throughout this paper.

3 Threat Landscape

We organize the attack surface of federated medical imaging into four categories.

3.1 Model and Data Poisoning

In a poisoning attack, a malicious client submits updates deliberately crafted to bias the global model, rather than updates reflecting honest training [5]. Poisoning can operate on the client's local data (e.g., label flipping, where diagnostic labels are deliberately swapped) or directly on the submitted update (e.g., scaling the update by a large factor to amplify its influence on the aggregate, a strategy sometimes called a model-replacement attack). Because FedAvg's weighting is typically proportional to a client's reported dataset size, and because that size is often self-reported and unverified, an attacker can also inflate its apparent influence simply by misreporting n_k.

3.2 Backdoor Attacks

Backdoor attacks [7] are a targeted variant of poisoning. The attacker's goal is not to degrade overall accuracy (indeed, a successful backdoor typically preserves normal-looking performance on the main task), but to implant a hidden trigger pattern that causes a specific misclassification whenever it appears. In a clinical imaging context, this could mean a model that behaves normally on almost all scans, but consistently misclassifies images bearing a particular, attacker-chosen visual artifact. Backdoors are especially hard to detect precisely because global validation-set accuracy does not reveal them.

3.3 Byzantine Participants

More generally, a Byzantine client is one that can send arbitrary, potentially adversarially coordinated updates to the server, without any constraint that those updates correspond to any real training process at all [2]. Byzantine-robust aggregation rules are designed to bound the influence of such clients under an assumed upper bound on the number of malicious participants. As discussed above, the central practical difficulty in medical imaging is that these rules must distinguish Byzantine behavior from the natural heterogeneity of non-IID hospital data, and can fail in either direction: under-protecting against a well-camouflaged attacker, or over-penalizing an honest hospital whose legitimate patient population differs from the majority.

3.4 Inference and Gradient Leakage

Even without any poisoning, the shared model updates themselves can leak information about the underlying training data. Membership inference attacks [9] attempt to determine whether a specific patient record was used in training a given client's local model. Gradient inversion and feature-leakage attacks [10] attempt to reconstruct approximations of training inputs, or characteristics of the local training population, from the gradients or weights a client submits. In medical imaging specifically, this raises the possibility that an honest but curious aggregator, or an eavesdropper on the communication channel, could infer sensitive information such as which hospital treated a given type of case, or, in adversarial reconstructions, approximate image content.

4 Defenses and Safeguards

No individual defense addresses all of the threats above, and each involves a distinct set of trade-offs among privacy, robustness, accuracy, and computational or communication cost.

4.1 Secure Aggregation

Secure aggregation protocols [3] use cryptographic masking so that the server can only recover the sum (or average) of client updates, never any individual client's update in isolation. This can substantially mitigate server-side attacks that require access to individual client updates, since secure aggregation prevents the server from directly observing an individual client's unmasked update. The cost is that secure aggregation is fundamentally in tension with server-side anomaly detection: a server that cannot see individual updates also cannot flag an individual update as statistically anomalous, which limits the applicability of Byzantine-robust aggregation and reputation-based defenses when secure aggregation is also in use.

4.2 Differential Privacy

Differentially private stochastic gradient descent (DP-SGD) [4] clips each client's per-example (or per-update) gradient contribution and adds calibrated random noise before submission. Depending on the formulation, differential privacy can provide example-level or client-level privacy guarantees: standard DP-SGD clipping and noise addition, as originally formulated, limits the influence of individual training records, while client-level DP requires a separate formulation that clips and bounds the contribution of each participant as a whole. This provides a rigorous, quantifiable privacy guarantee at whichever level it is applied, but the clipping and noise addition directly trade off against model accuracy, and the trade-off worsens as the privacy budget is tightened.

4.3 Byzantine-Robust Aggregation

A family of aggregation rules replace the simple weighted mean of FedAvg with a statistic designed to be resilient to some fraction of adversarial updates. In this paper we evaluate three widely used rules:

- **Krum** [2] selects, in each round, the single client update whose sum of squared distances to its $n - f - 2$ nearest neighbors (for an assumed bound f on malicious clients) is smallest, and uses that one update as the new global model, discarding all others for that round.
- **Trimmed Mean** [6] computes, independently for each coordinate of the model's parameter vector, the mean of the values remaining after discarding the largest and smallest β fraction of client values at that coordinate.
- **Coordinate-wise Median** [6] similarly operates coordinate-by-coordinate, but takes the median value at each coordinate rather than a trimmed mean.

An alternative approach, **FLTrust** [11], sidesteps the need to assume a specific bound on the number of malicious clients altogether by having the server maintain a small, trusted root dataset representative of the federation, and re-weighting client updates according to their cosine similarity with the server's own update computed on that trusted set. This removes the client-count assumption but introduces a new requirement: a curated dataset representative of the federation as a whole, which may itself be difficult to construct for a genuinely heterogeneous hospital population.

4.4 Anomaly Detection and Reputation

Rather than judging each round in isolation, reputation-based defenses such as FLDetector [8] track the trajectory of each client's updates across multiple rounds, flagging clients whose behavior becomes inconsistent with a plausible honest training trajectory over time. This adds a temporal dimension that can catch attacks a single-round statistical test would miss, at the cost of requiring the server to retain and analyze a longer history of client behavior, which itself is only possible when secure aggregation is not simultaneously hiding individual updates.

4.5 Participant Authentication

Finally, at the level of federation membership rather than individual updates, access committees and cryptographic institutional identity are used to vet which hospitals may join a federation at all, guarding against Sybil attacks in which an adversary attempts to control multiple ostensibly independent participants.

4.6 The Core Trade-off

Across all of the above, four dimensions (privacy, robustness, accuracy, and cost) pull against each other, and no defense we reviewed optimizes all four simultaneously. Stronger differential privacy and more aggressive outlier filtering both tend to reduce accuracy on honest data; secure aggregation strengthens privacy but weakens the server's ability to detect anomalies; and Byzantine-robust and reputation-based methods add non-trivial computation and, in some cases, communication overhead. The right choice among these depends on the assumed threat model and the deployment's specific privacy and robustness requirements, and is unlikely to be the same choice for every clinical FL deployment.

5 Experimental Setup

To move beyond a purely qualitative survey, we implemented a small but realistic federated learning testbed and measured the empirical impact of poisoning under different aggregation rules.

5.1 Dataset

We use the real, publicly available Chest X-Ray Images (Pneumonia) dataset [13], consisting of 5,863 pediatric chest radiographs labeled as either normal or pneumonia. Images were resized to 48×48 pixels to keep per-round training time small enough to run many federated configurations.

5.2 Federation Simulation

We simulate five hospitals by partitioning the training pool into five disjoint subsets. To reflect realistic non-IID conditions, the subsets are constructed with differing pneumonia prevalence, ranging from 30% to 70% across the five simulated hospitals, rather than being drawn identically from the overall pool.

5.3 Model

Each simulated hospital trains a small convolutional neural network with 75,041 parameters on 48×48 input images. The model is intentionally lightweight so that fifteen federated training rounds, across five simulated clients and five aggregation configurations, could be run to completion with a fixed random seed for reproducibility.

5.4 Attack Configuration

One of the five simulated hospitals is designated malicious. The attack combines two components: (1) label flipping, in which the malicious hospital's local pneumonia/normal labels are deliberately inverted before local training, and (2) update scaling, in which the resulting malicious update is multiplied by a factor of 8× before submission. Because FedAvg weights client updates by reported dataset size, this update-scaling step raises the malicious hospital's effective influence on the aggregate from approximately 21% (its natural share of the training data) to approximately 68%.

5.5 Reproducibility Notes

All reported numbers come from an actual executed run using a fixed seed and genuinely disjoint per-hospital data partitions. During development we identified and corrected two implementation bugs that would otherwise have silently produced plausible-looking but incorrect results: an all-zero weight initialization that froze the CNN's gradients without raising any error, and a data-sampling step that inadvertently allowed different simulated hospitals to share identical images, which would have artificially understated the effect of non-IID partitioning. We flag both here because each is representative of a broader class of federated learning implementation errors that can silently invalidate reported results without any visible failure.

6 Results

6.1 Overall Accuracy

Table 1 reports final global model test accuracy after 15 federated training rounds under five aggregation configurations: unattacked FedAvg, poisoned FedAvg, and the poisoning attack under each of the three Byzantine-robust rules.

Table 1: Final Global Model Accuracy After 15 Federated Rounds

Aggregation	Accuracy
FedAvg (no attack)	79.8%
FedAvg (poisoned)	50.0%
Trimmed Mean	82.8%
Median	75.0%
Krum	83.0%

Under standard FedAvg, a single malicious hospital out of five (using only label flipping and 8× update scaling) collapsed classification accuracy from 79.8% to 50.0%, effectively reducing the model to chance-level performance on this binary classification task. All three Byzantine-robust rules substantially recovered accuracy under the same attack, but not to a uniform degree: Krum (83.0%) and Trimmed Mean (82.8%) both slightly *exceeded* the unattacked FedAvg baseline, while Median (75.0%) recovered to somewhat below it, despite Median and Trimmed Mean carrying comparable theoretical robustness guarantees in the literature. We attribute this gap to Median discarding more usable information per coordinate than a

trimmed average retains, particularly under the non-IID prevalence differences across our five simulated hospitals.

6.2 Convergence Behavior

Figure 1 plots test accuracy across all 15 federated rounds for each configuration. Two convergence patterns are notable. First, honest (unattacked) FedAvg and poisoned FedAvg both stabilize by round 2, but in opposite directions: the honest run converges quickly to its final accuracy, while the poisoned run collapses immediately rather than degrading gradually, indicating that this particular attack configuration is effective from the very first rounds rather than accumulating damage slowly over time. Second, both Trimmed Mean and Median stabilize by round 3, comparable to the honest baseline, while Krum converges more slowly, stabilizing around round 7. We attribute Krum's slower convergence to its selection mechanism: because Krum selects a single client's full update as the entire global model update for a round, rather than blending information across all clients as Trimmed Mean and Median do, it discards useful gradient information from the four honest clients that were not selected in any given round.

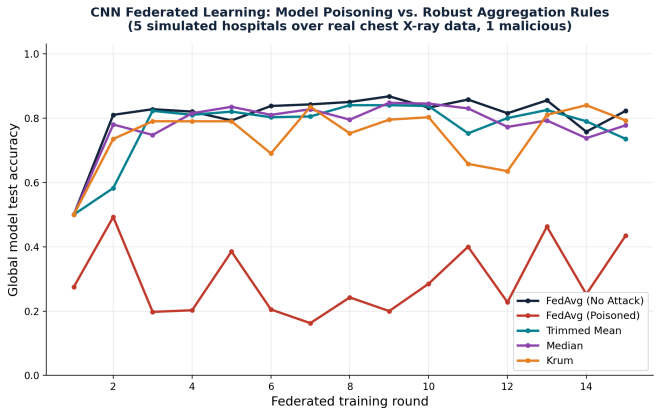


Figure 1: Global model test accuracy across 15 federated training rounds, comparing honest FedAvg, poisoned FedAvg, and the same poisoning attack under Trimmed Mean, Median, and Krum aggregation. Five simulated hospitals, one malicious, real chest X-ray data.

6.3 Computational Cost

All three Byzantine-robust defenses added negligible overhead on top of ordinary CNN training time in our setting: every configuration completed in 1.7–1.8 seconds on GPU per full run, with the sole exception of the honest FedAvg run's reported 9.0 seconds, which reflects a one-time CUDA warm-up cost rather than any property of the aggregation rule itself. We note, however, that Krum's pairwise-distance computation is $O(n^2)$ in the number of participating clients; at $n = 5$ this cost is trivial, but this ceases to hold once a federation scales to the hundreds of hospitals that a national or multi-institutional deployment might involve.

7 Discussion

7.1 Byzantine-Robust Methods Are Not Interchangeable

Our central empirical finding is that Krum, Trimmed Mean, and Median, despite being drawn from the same family of Byzantine-robust aggregation rules and carrying broadly similar theoretical guarantees in the literature, produced final accuracies spanning an 8-percentage-point range (75.0% to 83.0%) under an identical attack and identical data. This is a caution against treating "Byzantine-robust aggregation" as a single, interchangeable defense category when selecting a method for a real deployment: the specific rule matters, and the ranking among rules may itself depend on the degree and structure of non-IID heterogeneity present, which will vary across real hospital federations.

7.2 Choosing a Defense in Practice

Each defense surveyed in Section IV assumes a different threat model, and that assumption should drive selection. Krum and Trimmed Mean/Median require an operator to specify, in advance, a rough bound on the number of malicious clients the system should tolerate, and both can degrade in unpredictable ways if that bound is set incorrectly. FLTrust avoids this specific assumption, but substitutes a different practical requirement: a small trusted dataset that is genuinely representative of the federation's overall population, which may be difficult to assemble precisely in the highly heterogeneous hospital settings this paper is concerned with. Anomaly-detection and reputation-based methods add a useful temporal dimension by tracking client behavior across rounds, but require retaining a longer history of individual client updates, which is fundamentally incompatible with deploying secure aggregation at the same time, since secure aggregation is designed specifically to prevent the server from ever seeing an individual client's update.

More broadly, no defense examined in this paper is free. Secure aggregation protects privacy precisely by hiding individual client updates from the server, but this is the same property that prevents any server-side anomaly detection. Differential privacy provides a mathematically rigorous bound on any single training example's or client's influence on the released model, but only at a direct, quantifiable accuracy cost. Byzantine-robust aggregation methods can, by design, down-weight or discard updates that look statistically unusual; in a highly non-IID medical setting, an honest hospital serving an atypical patient population is a normal occurrence, not a rare edge case, meaning these methods carry a real risk of systematically

disadvantaging exactly the hospitals whose patient populations differ most from the federation's majority.

7.3 Medical-Imaging-Specific Considerations

Two properties of clinical deployments sharpen the stakes of the analysis above beyond what is typical in FL's original cross-device motivating use cases. First, hospital data is highly non-IID by nature (in disease prevalence, in imaging equipment and acquisition protocol, and in patient demographics), which structurally weakens the core assumption behind most Byzantine-robust aggregation rules, that honest updates should look statistically similar to one another. Second, the stakes of a compromised model are clinical rather than purely academic: a poisoned or backdoored classifier does not merely lower a benchmark accuracy number, it can directly shape a real diagnostic decision for a real patient. On the regulatory side, federated learning can support privacy-preserving data collaboration by reducing the need to centralize or transfer raw patient data; however, regulatory compliance under HIPAA, GDPR, and India's DPDP Act requires additional organizational and technical safeguards beyond federation itself. However, regulators are increasingly expected to require this data-locality property to be paired with concrete technical guarantees (differential privacy budgets, access control, and auditable aggregation) rather than treating the federated architecture itself as a sufficient security guarantee in isolation.

7.4 Limitations

Our empirical study has several limitations that should temper generalization of the specific numeric results. The federation size (five simulated hospitals) and model size (75,041 parameters) are small relative to real multi-institutional deployments, chosen deliberately to allow many configurations to be run to completion under a fixed seed; larger federations may exhibit different convergence and robustness behavior, and Krum's $O(n^2)$ cost, in particular, may become material at realistic federation scale. We evaluate a single attack configuration (label flipping plus 8× update scaling from one malicious hospital) and a single dataset and task (binary pneumonia classification on pediatric chest radiographs); results may differ for other attack strengths, other numbers of malicious participants, other imaging modalities, and multi-class diagnostic tasks. We did not evaluate combinations of defenses (for example, differential privacy layered on top of a Byzantine-robust aggregation rule), which is a natural direction for further work given that the defenses surveyed in Section IV address partially distinct threat models.

8 Conclusion

Federated learning removes the requirement to centralize raw patient data, which is a genuine and valuable step toward privacy-preserving multi-institutional medical AI. However, our survey and experiments both support the same underlying conclusion: removing the need to centralize data does not, by itself, secure the resulting system. Poisoning, backdoor, and inference risks are introduced by the federated protocol itself and must be explicitly engineered around, using defenses whose trade-offs are understood and matched to the deployment's actual threat model, rather than assumed away as a side effect of the architecture. Our chest X-ray experiments show concretely that, in this five-hospital configuration, a single malicious participant using label flipping and 8× update scaling reduced the evaluated diagnostic classifier to chance-level accuracy under standard aggregation, and that Byzantine-robust alternatives, while effective in this setting, are not interchangeable: their relative performance differs by a meaningful margin even under identical attack conditions. These findings should not be generalized beyond the evaluated configuration without further study. Building trustworthy federated medical AI therefore requires matching the defense stack to the clinical stakes of each specific deployment, and validating that defense stack empirically on real, non-IID clinical data, rather than relying on federation alone, or on theoretical guarantees alone, as a substitute for that validation.

Acknowledgment

The authors thank the organizers of CAICS 2026 (Colloquium on AI & Cybersecurity), co-hosted with Argonne National Laboratory and the Indian Institute of Science (IISc), Bengaluru, and acknowledge support from the U.S. Department of State's academic exchange programs in connection with this work.

References

[1] H. B. McMahan, E. Moore, D. Ramage, S. Hampson, and B. A. y Arcas, "Communication-efficient learning of deep networks from decentralized data," in *Proc. 20th Int. Conf. Artif. Intell. Statist. (AISTATS)*, 2017.

[2] P. Blanchard, E. M. El Mhamdi, R. Guerraoui, and J. Stainer, "Machine learning with adversaries: Byzantine tolerant gradient descent," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2017.

[3] K. Bonawitz et al., "Practical secure aggregation for privacy-preserving machine learning," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur. (CCS)*, 2017.

[4] M. Abadi et al., "Deep learning with differential privacy," in *Proc. ACM SIGSAC Conf. Comput. Commun. Secur. (CCS)*, 2016.

[5] M. Fang, X. Cao, J. Jia, and N. Gong, "Local model poisoning attacks to Byzantine-robust federated learning," in *Proc. 29th USENIX Secur. Symp.*, 2020.

[6] D. Yin, Y. Chen, R. Kannan, and P. Bartlett, "Byzantine-robust distributed learning: Towards optimal statistical rates," in *Proc. 35th Int. Conf. Mach. Learn. (ICML)*, 2018.

[7] H. Wang et al., "Attack of the tails: Yes, you really can backdoor federated learning," in *Adv. Neural Inf. Process. Syst. (NeurIPS)*, 2020.

[8] Z. Zhang, X. Cao, J. Jia, and N. Z. Gong, "FLDetector: Defending federated learning against model poisoning attacks via detecting malicious clients," in *Proc. 28th ACM SIGKDD Conf. Knowl. Discov. Data Min. (KDD)*, 2022.

[9] R. Shokri, M. Stronati, C. Song, and V. Shmatikov, "Membership inference attacks against machine learning models," in *Proc. IEEE Symp. Secur. Privacy (S&P)*, 2017.

[10] L. Melis, C. Song, E. De Cristofaro, and V. Shmatikov, "Exploiting unintended feature leakage in collaborative learning," in *Proc. IEEE Symp. Secur. Privacy (S&P)*, 2019.

[11] X. Cao, M. Fang, J. Liu, and N. Z. Gong, "FLTrust: Byzantine-robust federated learning via trust bootstrapping," in *Proc. Netw. Distrib. Syst. Secur. Symp. (NDSS)*, 2022.

[12] M. J. Sheller et al., "Federated learning in medicine: Facilitating multi-institutional collaborations without sharing patient data," *Sci. Rep.*, vol. 10, no. 1, 2020.

[13] D. S. Kermany et al., "Identifying medical diagnoses and treatable diseases by image-based deep learning," *Cell*, vol. 172, no. 5, pp. 1122–1131, 2018.